

## Alert Triage & Incident Handoff

---

### The Triage Ladder: From Alert to Case

**Triage** (Tier 1) – "Is this real, known, or new?"

Check: asset crit, IOC match, unusual-for-this-victim?

**Verdicts:** benign / false positive / potentially suspicious

**Suspicious?** → escalate with context, not just the raw event

**Confirmed incident?** → IR (module 13)

### The Analyst's Checklist (Do It in Order)

- [ ] What's the asset (crown jewel? internet-facing? whose?)
- [ ] What does the tech say (rule, ATT&CK technique, correlation?)
- [ ] Gather evidence NOW (screenshots, logs, process lists) – sources go stale
- [ ] Never "just look" – formulate a hypothesis to test
- [ ] Check the obvious: known-malicious IOCs? false-positive pattern? expected business activity?

**The red flag:** an alert that "feels off" but nothing is definitive – that's not "false alarm, moving on", that's "needs a second set of eyes and 2 more log queries."

### Evidence: Chain of Custody Basics

When you keep something for investigation/legal:

Collect & label at collection time (who, when, where, how)

Hash it (SHA-256) – the hash is the "fingerprint" that proves nothing changed

Preserve original media read-only; work on a **copy**

Document every transfer

For everyday triage: capture `time-stamped, context-rich` evidence (hostname, timestamp, rule ID, source logs, user).

## The Escalation Artifact

What Tier 2 IR folks WANT on handoff (not an alert dump):

`Summary` – what happened in 2-3 sentences

`Evidence` – the 3-4 critical logs/events, screenshots

`Context` – asset criticality, business function

`Hypothesis` – what you think it is, what you tested

`Recommended next steps` – what IR should run

**Triage is a confidence game, not a certainty game.** Document uncertainty loud and clear – "could not rule out" beats silent dismissal.

## The Kill-Chain-Beacons, Part 2

From M08: the kill chain (delivery → exec → persistence → c2 → action).  
Triage answers "WHICH stage?":

Only delivery? (phish landed, nothing executed) → fewer alarms

C2 beaconing? → now it's a sprint, not a jog

Actions on objective? → full IR, isolate the host

## Metrics That Matter for Triage

First-response time (to first query)

Time-to-verdict

Escalation quality (was the handoff actually usable?)

FP reduction over time (are you tuning rules?)

**Bottom line:** an un-triaged alert might as well not exist. The analyst's judgment – deciding *when to robotically follow policy vs when to think* – is the SOC's real asset.

---

[← Correlation & Detection Engi...](#)

Module complete ✓